

N-BaIoT：基于网络的物联网僵尸网络攻击检测

使用深度自编码器

- ☐ **原文题目**：N-BaIoT: Network-based Detection of IoT Botnet Attacks Using Deep Autoencoders
- ☐ **作者**：Yair Meidan、Michael Bohadana、Yael Mathov、Yisroel Mirsky、Dominik Breitenbacher、Asaf Shabtai、Yuval Elovici
- ☐ **arXiv**：1805.03409v1 [cs.CR]，2018 年 5 月 9 日
- ☐ **DOI**：原文未提供
- ☐ **许可**：CC BY-NC-SA 4.0
- ☐ **声明**：非官方中文译本

原文发表于 IEEE PERVASIVE COMPUTING，第 13 卷，第 9 期，2018 年 7 月—9 月。

摘要（Abstract）

物联网（Internet of Things, IoT）设备比桌面计算机更容易遭到入侵，其大量普及导致基于物联网的僵尸网络攻击发生率上升。为了缓解这一新威胁，需要开发新的方法，以检测由遭入侵的物联网设备发起的攻击，并区分持续数小时和数毫秒的基于物联网的攻击。本文提出并实证评估了一种新颖的基于网络的异常检测方法：该方法提取网络的行为快照，并使用深度自编码器检测来自遭入侵物联网设备的异常网络流量。为评估该方法，我们在实验室中使用两种最知名的基于物联网的僵尸网络 Mirai 和 BASHLITE 感染了九台商用物联网设备。评估结果证明，所提出的方法能够准确且即时地检测出属于僵尸网络的遭入侵物联网设备正在发起的攻击。

关键词（Index Terms）——物联网，僵尸网络，异常检测，自编码器。

1 引言（INTRODUCTION）

随着全球部署的物联网（IoT）设备数量急剧增加 [1]，并且基于物联网的分布式拒绝服务（Distributed Denial of Service, DDoS）攻击流量达到前所未有的规模 [1]、[2]、[3]，及时检测物联网僵尸网络攻击已经成为降低这些攻击相关风险的当务之急。即时检测有助于网络安全，因为它能够加快对遭入侵物联网设备的告警和断网，从而阻止僵尸网络传播，并防止进一步的出站攻击流量。

诸如 Mirai 的僵尸网络通常由几个不同的运行步骤构成 [1]，即传播、感染、命令与控制（command-and-control, C&C）通信以及攻击执行。与先前的大多数僵尸网络检测研究（见表 1）不同，本文关注最后一个步骤。我们聚焦于大型企业：预计这类企业将面对种类和数量不断增长的物联网设备，这些设备通常通过 Wi-Fi 接入其网络（Bluetooth 和 ZigBee 等短距离通信不在本文范围内）。这些设备既可能是自行部署的（例如智能烟雾探测器），也可能是由员工和访客从外部动态带入的（例如自带设备（Bring Your Own, BYO）可穿戴设备）。

假设僵尸网络攻击不太可能消失，我们要回答的根本问题如下：给定大量异构物联网设备连接到组织网络的情形，我们能否设计一种集中式、自动化的方法，高效且准确地检测已经加入僵尸网络并被用于发起攻击的遭入侵物联网设备？

为了检测由物联网僵尸发起的攻击，我们提出一种基于网络的方法，使用深度学习技术执行异常检测。具体而言，我们提取能够捕获良性物联网流量行为快照的统计特征，并训练深度自编码器（每台设备一个）来学习物联网的正常行为。深度自编码器尝试压缩快照。当自编码器无法重构某个快照时，这就强烈表明所观察到的行为是异常的（即物联网设备已经遭到入侵并表现出未知行为）。使用深度自编码器的一个优点是其学习复杂模式的能力，例如各种设备功能的模式。这会产生一个几乎没有误报的异常检测器。我们通过实证表明，自编码器的误报率明显低于另外三种常用于异常检测的算法 [13]。

使用这种方法检测受感染物联网设备的好处如下：

异构性容忍（Heterogeneity tolerance）。与经典计算环境相比，物联网领域高度多样化 [2]、[3]。然而，通过使用单独的自编码器为每台设备建立画像，我们的方法能够应对物联网设备日益增长的异构性。

****开放世界（Open World）。**** 通常，在深度学习应用中，模型依据专家提供的标签（例如恶意或良性）进行训练和分类。然而，我们的自编码器经过训练后检测行为何时异常。因此，鉴于不断演化的变种 [2] 或新僵尸网络已经使大多数检测方法过时 [14]，我们的方法能够检测新的、此前“未见过”的僵尸网络行为。

****效率（Efficiency）。**** 在企业场景中，通常会监控所有已连接主机的流量数据，但被监控流量的数量大到难以存储并用于训练深度神经网络。我们的方法使用增量统计量执行特征提取，并且编码器的训练可以在线半自动进行（在一批观测上训练，然后丢弃该批数据）。因此，训练是可行的，不存在存储方面的顾虑。此外，我们的方法基于网络，所以不会消耗（通常资源受限的）物联网设备的计算、内存或能量资源。因此不会损害其功能或缩短其寿命。我们关注攻击运行步骤（而非早期步骤），也使得我们的方法不依赖僵尸网络的传播协议以及可能经过加密的 [14] C&C 信道。

本文的贡献可概括如下：

- 1. 据我们所知，我们首次将自编码器应用于物联网网络流量，用作检测僵尸网络攻击的完整手段。即使在更广泛的网络流量分析领域，自编码器也尚未被用作完全自动化的独立恶意软件检测器；它们更多是作为特征学习 [15] 或降维 [16] 的初步工具，或者至多作为半人工的离群点检测器，严重依赖人工标注以便后续分类 [17] 或进一步由安全分析师检查 [13]。
- 2. 与先前依赖仿真或模拟数据的物联网僵尸网络或物联网流量异常检测实验研究（[4]、[7]、[8]、[10]）不同，我们使用真实流量数据进行实证评估。这些数据来自被两个家族的真实僵尸网络感染的九台商用物联网设备。我们研究了 Mirai 和 BASHLITE，这两种最常见的基于物联网的僵尸网络已经展示了其危害能力 [1]。为实现可复现性并解决缺少公开僵尸网络数据集（尤其是物联网数据集）的问题 [14]，我们共享了网络跟踪数据，网址为：
`http://archive.ics.uci.edu/ml/datasets/detection of IoT botnet attacks N BaloT`。

有关更多细节以及数据集本身，可访问：`http://archive.ics.uci.edu/ml/datasets/detection of IoT botnet attacks N BaloT`。

表 1：先前开展的物联网相关异常、僵尸网络和恶意软件攻击检测研究

原文表格的列为：****论文****；****检测到的僵尸网络****；****僵尸网络运行步骤****；****攻击****；****检测方法****；****部署层级****；****假设环境****；****研究类型****；****用于评估的数据****。原文排版提取时部分单元格跨行错位，以下保留原有数据和可辨认的对应关系：

论文	检测到的僵尸网络/对象	运行步骤或攻击	检测方法	部署层级	假设环境	研究类型	数据
[2]	—	DDoS	—	—	—	调查	—
[3]	Linux.Darll0z	感染	入侵防御、流量监控	网络（路由器、网关）	—	调查	—
[4]	worm、Mirai	DDoS	—	—	—	实验	—
[5]	各种	取决于恶意软件的运行步骤	—	—	—	—	—
[6]	Mirai	Mirai 感染的物联网设备扫描其他设备	—	—	—	实验	—
[7]	Mirai	扫描（传播）	动态更新流规则	“薄雾”（thin fog）	关键基础设施	实验	仿真物联网节点、模拟数据
[8]	—	蠕虫传播、代码注入、隧道攻击	—	主机	—	实验	两台真实设备
[9]	ZORRO、*.sh、GAFGYT、KOS、nttpd	—	深度数据包异常检测	主机和网络	WSN	实验	真实数据
[10]	—	设备遭受 DoS 攻击	蜜罐，用于收集和分析攻击	网络（路由器和根节点）	代表智慧城市的 6LoWPAN WSN	调查	仿真

论文	检测到的僵尸网络/对象	运行步骤或攻击	检测方法	部署层级	假设环境	研究类型	数据
[11]	—	路由攻击 (sinkhole 和 selective-forwarding)	混合：基于签名和基于异常的检测 (BPN)	网络 (云)	传感系统与分布式云平台	实验	—
[12]	—	—	混合：基于规范和基于异常的检测 (OFPC)	网络 (边界路由器和主机)	适配 ZigBee/XBee、6LoWPAN (基于 IEEE 802.15.4)、WiFi (基于 IEEE 802.11) 和 BT	实验	真实设备、模拟数据
—	—	ICMP flood、复制、wormhole、TCP SYN flood、HELLO jamming、数据修改、选择性转发、smurf	包括异常检测在内的若干方法	主机和网络	6LoWPAN	调查/仿真	—
—	—	诸如伪造或篡改信息、sinkhole、选择性转发等路由攻击	知识驱动的正常检测	—	—	—	—
—	—	—	混合：基于签名和基于异常的检测	—	—	—	—

2 相关工作 (RELATED WORK)

迄今提出的僵尸网络检测方法可以根据 (1) 要检测的具体运行步骤以及 (2) 检测方法进行分类。表 1 基于这一分类，并进一步总结了此前针对物联网相关异常、僵尸网络和恶意软件攻击的研究。

在僵尸网络的运行步骤中，先前与物联网相关的检测研究 (例如 [4] 和 [5]) 主要关注传播以及与 C&C 服务器通信等早期步骤。然而，鉴于僵尸网络攻击每天都在继续变异 [1] 并变得越来越复杂 [2]，我们预计其中一些变异最终会成功绕过现有的早期检测方法。此外，移动物联网设备在连接到外部网络时可能受到感染。例如，智能手表的所有者到达机场时，智能手表可能连接到可疑的免费 Wi-Fi 网络。因此，仅监控组织网络以识别感染的早期步骤是不够的。相应地，我们关注僵尸网络运行的较晚步骤，即物联网僵尸开始发起网络攻击时。在这个意义上，我们的方法增加了一层最后防线式的安全防护。它能够即时检测基于物联网的攻击，并通过发出立即隔离建议 (建议将任何遭入侵设备与网络隔离，直到完成清理) 来最大限度地降低攻击影响。

在所提出的僵尸网络检测方法中，一个主要区分是基于主机的方法 [5]、[7] 与基于网络的方法 [4]、[8]、[9]、[10]。我们认为，基于主机的技术对于检测遭入侵物联网设备而言不太现实，原因是：(1) 我们不能指望所有物联网制造商都愿意在其产品上安装指定的基于主机的异常检测器；(2) 某些物联网设备 (例如可穿戴设备) 的访问受到限制，无法强制在终端设备上安装软件；(3) 大多数物联网设备的计算和电量受限，这会限制基于主机的异常检测算法的复杂度和效率，并可能消耗设备的能量和计算资源，从而损害其功能；(4) 在我们设定的企业场景中，各种且数量众多的物联网设备连接到组织网络，单一的非分布式解决方案更受青睐。

文献 [14] 提出了一种不局限于物联网领域的、基于网络的僵尸网络检测方法分层分类法。蜜罐是该研究考察的检测来源之一。蜜罐通常用于收集、理解、刻画和追踪僵尸网络 [6]。然而，它们并不一定适合检测遭入侵的端点或从这些端点发出的攻击。此外，蜜罐通常需要在真实设备的采购或仿真、数据检查、签名提取以及跟上变异方面投入大量资源。按照 [14] 的观点，正常网络构成了另一种检测来源：网络入侵检测系统 (Network Intrusion Detection System, NIDS) 持续且自动地监控流量数据，同时使用模式匹配检测不良活动的迹象。这些模式可能依赖于：(1) 蜜罐识别的签名；(2) 与潜在 C&C 服务器相关的 DNS 流量；(3) 流量异常 [5]；(4) 数据挖掘；或 (5) 混合方法 [7]、[8]。与 [5] 类似，我

们发现，基于异常的方法最适合检测遭入侵的物联网设备，因为这些联网设备通常面向任务（例如专门用于检测运动或测量湿度）。因此，它们执行的网络协议更少、可能也不那么复杂，并且其流量相比个人计算机具有更小的方差。这样，检测偏离其正常模式的行为应当更准确、更稳健。

文献 [14] 调查了许多检测算法，但没有引用人工神经网络，也完全没有提到自编码器。此后，网络安全这一更广泛领域发表了相关工作，但它们与我们的方法不同、与物联网无关，并且通常不直接连接到僵尸网络。例如，[15]、[16] 和 [18] 应用浅层自编码器进行初步特征学习和降维，随后分别使用随机森林（Random Forest）、深度信念网络（Deep Belief Networks）和 Softmax 进行分类及微调。尽管 [17] 将自编码器扩展用于离群点检测，但仍然要求安全分析师主动标注数据，以便后续进行监督学习。与我们的方法更接近的是 [13] 的工作：该工作将深度学习应用于系统日志，以检测内部威胁。与我们不同，他们使用深度神经网络（DNN）和循环神经网络（RNN，长短期记忆网络（LSTM）），并依赖进一步的人工检查。

总之，我们的方法与先前研究的区别在于：我们从良性数据中学习，为每台设备训练深度自编码器，并将其作为独立的自动化工具，即时检测现有的和未见过的物联网僵尸网络攻击。

3 提出的检测方法（PROPOSED DETECTION METHOD）

我们提出的物联网僵尸网络攻击检测方法依赖于为每台设备分别建立的深度自编码器；这些自编码器使用从良性流量数据中提取的统计特征进行训练。当该方法应用于某台物联网设备的新数据（可能已经感染）时，检测到的异常可能表明该设备已遭到入侵。该方法包括以下主要阶段：（1）数据收集；（2）特征提取；（3）训练异常检测器；（4）持续监控。

数据收集（Data collection）

我们通过对交换机进行端口镜像来捕获原始网络流量数据（pcap 格式），组织流量通常会经过该交换机。为确保训练数据不含恶意外行为，在物联网设备接入网络后立即收集其正常流量。

特征提取（Feature extraction）

每当一个数据包到达时，我们就对与该数据包通信的主机和协议进行行为快照。该快照通过在若干时间窗口内提取 115 个流量统计量，来概括以下全部流量的上下文：（1）一般而言源自同一 IP 的流量；（2）源自同一个源 MAC 和同一个 IP 地址的流量；（3）在源 IP 与目的 IP 之间发送的流量（信道（channel））；（4）在源到目的 TCP/UDP 套接字之间发送的流量（套接字（socket））。

我们从最近的 100ms、500ms、1.5sec、10sec 和 1min 五个时间窗口中提取同一组 23 个特征（捕获上述内容，见表 2）。这些特征可以非常快速地、以增量方式计算，因此有助于对恶意数据包进行实时检测。此外，尽管这些特征是通用的，但它们能够捕捉特定行为，例如 Mirai 攻击特有的源 IP 欺骗 [2]。例如，当遭入侵的物联网设备伪造 IP 时，按源 MAC-IP、源 IP 和信道聚合的特征会立即因来自伪造 IP 地址的未见行为而显示出较大的异常。

表 2：提取的特征

值	统计量	聚合方式	特征总数
数据包大小（仅出站数据包）	均值、方差	源 IP□、源 MAC-IP□、信道、套接字□	8
数据包计数	数量	源 IP、源 MAC-IP、信道、套接字	4
数据包抖动（数据包到达之间的时间量）	均值、方差、数量	信道	3
数据包大小（入站和出站数据包均计）	幅度、半径、协方差、相关系数	信道、套接字	8

- 1. 源 IP 用于跟踪整个主机。
- 2. 源 MAC-IP 增加了区分来自不同网关以及伪造 IP 地址的流量的能力。

3. 套接字由源和目的 TCP 或 UDP 端口号确定。例如，从 `192.168.1.12:1234` 发往 `192.168.1.50:80` 的全部流量（从一个套接字流向另一个套接字的流量）。

训练异常检测器 (Training an anomaly detector)

作为基础异常检测器，我们使用深度自编码器，并分别为每台物联网设备维护一个模型。自编码器是一种神经网络，经过训练后能够在一定压缩之后重构其输入。压缩确保网络学习输入特征中有意义的概念及其关系。如果自编码器只使用良性实例进行训练，那么它会成功重构正常观测，但会无法重构异常观测（未知概念）。当检测到显著的重构误差时，我们就把给定观测分类为异常。

我们优化每个训练模型的参数和超参数，使其应用于未见流量时最大化真正例率（True Positive Rate, TPR，即攻击发生后将其检测出来）并最小化假正例率（False Positive Rate, FPR，即错误地将良性数据标记为恶意）。对于训练和优化，我们使用两个只包含良性数据的独立数据集，模型从这些数据中学习正常活动的模式。第一个数据集是训练集（DStrn），用于训练自编码器，其输入参数包括学习率（[原文此处无法识别]，梯度下降步长的大小）和 epoch 数（完整遍历整个 DStrn 的次数）。第二个数据集是优化集（DSopt），用于迭代优化这两个超参数（[原文此处无法识别] 和 epochs），直到模型输入（原始特征向量）与输出（重构特征向量）之间的均方误差（MSE）不再下降。在此时停止可以防止对 DStrn 过拟合，从而促进模型在未来数据上获得更好的检测结果。随后，DSopt 用于优化区分良性和恶意观测的阈值（tr）；最后，它还用于优化窗口大小（ws），以最小化 FPR。

模型训练和优化完成后，即确定 tr。异常阈值（高于该阈值的实例被视为异常）按 DSopt 上 MSE 的样本均值与标准差之和计算（见公式 1）：

$$tr = MSE_DSopt + s(MSE_DSopt) \quad (1)$$

初步实验表明，仅根据单个实例决定设备的数据包流是否异常，能够非常准确地检测基于物联网的僵尸网络攻击（TPR 高）。然而，良性实例过于频繁地（约在 5 - 7% 的情况下）被错误标记为异常。因此，我们通过在移动窗口上执行多数投票，根据一系列实例做出异常判定。我们将窗口大小 ws 确定为最短的实例序列，使得在 DSopt 上进行多数投票时产生 0% FPR（见公式 2）：

$$ws = \arg \min_{|ws|} (|\{packet : MSE(packet) > tr\}| > |ws| / 2) \quad (2)$$

持续监控以进行异常检测 (Continuous monitoring for anomaly detection)

最后，我们将优化后的模型应用于从持续观测的数据包中提取的特征向量，将每个实例标记为良性或异常。然后，对长度为 ws 的标记实例序列执行多数投票，用于决定整个相应流是良性还是异常。因此，一旦检测到异常流，就可以发出告警，因为这可能表明物联网设备正在进行恶意活动。

4 实证评估 (EMPIRICAL EVALUATION)

在实验中，我们努力真实地再现企业环境中部署的物联网设备、感染真实世界僵尸网络以及执行真实攻击的情形。

实验室设置 (Lab setup)

为了复制典型的组织数据流，我们从通过 Wi-Fi 连接到若干接入点的物联网设备收集流量数据；这些接入点通过有线连接接入中央交换机，中央交换机还连接到路由器。为嗅探网络流量，我们在交换机上执行端口镜像，并使用 Wireshark 记录数据。为了尽可能真实地评估检测方法，我们还在隔离实验室中部署了两个僵尸网络的全部组件（见图 1），并用它们感染了九台商用物联网设备（见表 3）。

图 1：用于检测物联网僵尸网络攻击的实验室设置

部署的僵尸网络 (Botnets deployed)

我们聚焦于两个最常见的物联网僵尸网络家族：BASHLITE 和 Mirai。我们在实验室部署了二者，并收集感染前后的流量数据。

****BASHLITE****（也称 Gafgyt、Q-Bot、Torlus、Lizard-Stresser 和 Lizkebab）是最臭名昭著的物联网僵尸网络类型之一，其代码和行为也可以在其他物联网恶意软件中找到。为了发起攻击，该僵尸网络通过暴力破解开放 Telnet 端口设备的默认凭据，感染基于 Linux 的物联网设备。在本研究中，我们使用 IoT POT 数据集 [6] 中的二进制文件（即 Gafgyt）感染物联网设备。为使攻击适应我们的实验室，我们从恶意软件的二进制文件中提取 C&C 服务器的 IP 地址，并将发往该 IP 的所有网络流量路由到实验室中的一台服务器，该服务器充当 C&C 服务器。新的僵尸连接到该服务器并受其控制后，该服务器便能够命令受感染设备发起攻击。

****Mirai**** 是我们在隔离网络中部署的第二个僵尸网络，使用的是其公开发布的源代码 [19]。实验设置包括一台 C&C 服务器以及一台带有扫描器和加载器的服务器。扫描器和加载器组件负责扫描和识别易受攻击的物联网设备，并将恶意软件加载到所检测到的易受攻击物联网设备上。设备感染后，会自动开始扫描网络中的新受害者，同时等待 C&C 服务器的指令。

执行的攻击（Attacks executed）

以下是在实验室中执行和测试的攻击列表。

BASHLITE 攻击

1. ****Scan****: 扫描网络中的易受攻击设备。
2. ****Junk****: 发送垃圾数据。
3. ****UDP****: UDP 泛洪。
4. ****TCP****: TCP 泛洪。
5. ****COMBO****: 发送垃圾数据，并向指定 IP 地址和端口打开连接。

Mirai 攻击

1. ****Scan****: 自动扫描易受攻击的设备。
2. ****Ack****: ACK 泛洪。
3. ****Syn****: SYN 泛洪。
4. ****UDP****: UDP 泛洪。
5. ****UDPplain****: 使用更少选项的 UDP 泛洪，为更高的 PPS 进行了优化。

实验结果与讨论（Experimental results and discussion）

我们在实验室收集的九组良性数据分别对应九台物联网设备；每台设备的数据按时间顺序分成三个大小相等的集合：（1）用于训练自编码器的 DStrn；（2）用于参数优化的 DSopt；（3）DStst 的良性部分，用于估计 FPR。为了模拟真实世界设置并因此真实地评估我们的方法，我们确保纳入设备完整（正常）生命周期中的流量。具体而言，在每台物联网设备的三个集合中，我们不仅包括频繁动作（例如摄像头传输视频）的流量数据，也包括不频繁动作（例如通过移动应用访问摄像头、在摄像头前移动或启动设备）的流量数据。

我们使用 Keras 进行训练和优化。每个自编码器都有一个输入层，其维度等于数据集中的特征数（即 115）。正如 [16] 和 [15] 所指出的，自编码器能够在内部有效地执行降维，因此，位于编码器和解码器之间的代码层可以有效压缩输入层，并反映其本质特征。在我们的实验中，编码器的四个隐藏层大小依次设置为输入层维度的 75%、50%、33% 和 25%。接下来的层是解码器，其大小与编码器相同，但顺序递增（从 33% 开始）。表 3 给出了训练阶段的技术细节，同时重点说明了数据集属性、自编码器的优化超参数以及僵尸网络感染情况。

表 3：训练阶段概览：数据集属性和训练摘要、自编码器的优化超参数以及僵尸网络感染

原文表格列为：****设备 ID****；****设备制造商和型号****；****设备类型****；****良性实例数****；****训练时间（sec）****；****对象大小（kB）****；****学习率****；****epoch 数****；****异常阈值（tr）****；****窗口大小（ws）****；以及 ****Mirai/BASHLITE 僵尸网络感染标记****。原始文本提取将部分表头和数值拆到相邻行；结合原文列出的九台设备，按设备名称顺序还原如下，感染标记（`!`、`!!`、`-!!`、`-`）原样保留：

设备 ID	设备制造商和型号	设备类型	良性实例数	训练时间 (sec)	对象大小 (kB)	学习率	epoch 数	异常阈值 (tr)	窗口大小 (ws)	感染标记
1	Danmini	门铃	49,548	54	172	0.012	800	0.042	82	!
2	Ennio	门铃	39,100	292	172	0.003	350	0.011	22	-!!
3	Ecobee	恒温器	13,113	275	172	0.028	250	0.011	20	!!
4	Philips B120N/10	婴儿监视器	175,240	795	172	0.016	100	0.030	65	!!
5	Provision PT-737E	安防摄像头	62,154	220	172	0.026	300	0.035	32	!!
6	Provision PT-838	安防摄像头	98,514	190	172	0.008	450	0.038	43	!!
7	SimpleHome XCS7-1002-WHT	安防摄像头	46,585	150	172	0.017	230	0.056	23	!!
8	SimpleHome XCS7-1003-WHT	安防摄像头	19,528	555	172	0.006	500	0.004	25	!
9	Samsung SNH 1011N	网络摄像头	52,150	215	172	0.013	150	0.074	32	-

注：原文表格的感染标记位于 Mirai 与 BASHLITE 两列；文本提取将这两列压缩成符号串，无法进一步可靠区分每个符号分别属于哪一列，因此仅保留原始标记串，不作拆分。

在自编码器训练和优化阶段之后，我们使用相同的（良性）数据训练另外三种常用于异常检测的算法 [13]：局部离群因子（Local Outlier Factor, LOF）、单类支持向量机（One-Class SVM）和孤立森林（Isolation Forest）。我们完全按照自编码器的方法优化它们的超参数，包括 tr 和 ws。最后，我们通过 Mirai 和 BASHLITE 的 C&C 服务器，以相同持续时间执行上述全部攻击。随后，我们从恶意数据中提取特征，并将 DStst 的每个良性部分（前文所述）附加到 DStst 相应的恶意部分，以便为每台物联网设备形成一个同时包含良性和恶意实例的单一测试数据集。

DStst 上的实验结果（见图 2）很有希望：

- 我们的方法成功检测了每台遭入侵物联网设备发起的每一次攻击，即 TPR 为 100%。如图 2(a) 所示，LOF 和 SVM 达到了相近的 TPR，明显优于表现出较低且高度可变 TPR 的孤立森林。
- 我们的方法还产生了最少的误报。其平均 FPR 为 0.007 ± 0.01 ，低于且比 SVM (0.026 ± 0.029)、孤立森林 (0.027 ± 0.041) 和 LOF (0.086 ± 0.081) 更稳定。
- 此外，我们的方法只需 $174 - 212$ 毫秒来检测攻击，而且通常所需时间少得多。如图 2(b) 所示，对于所评估的大多数物联网设备，我们方法的平均检测时间低于其他所有方法。假设检测到与攻击相关的异常可以自动触发立即隔离遭入侵设备，那么发起的攻击可以在不到一秒内停止。这相较于 DDoS 攻击的典型持续时间 [20] 是大幅缩短；DDoS 攻击的持续时间分布通常在 20 - 90 秒之间，此外还有长尾：10% 的攻击持续超过一天，2% 持续超过一个月。

图 2：使用测试集的实验结果：方法比较及潜在解释

- (a) 方法的检测准确率
- (b) 方法的检测时间（秒）
- (c) 由流量特征解释的平均 FPR
- (d) 由流量特征解释的检测时间

就 TPR、FPR 和检测时间而言，深度自编码器在大多数设备上表现出优越性。这可能是由于深度架构能够学习非线性结构映射并逼近复杂函数 [16]。此外，深度自编码器受到隐藏层降维所施加的复杂度约束，这阻止它们学习平凡的恒等函数 [13]。因此，深度自编码器往往比不常见模式更好地拟合常见模式。对于物联网设备来说这很有益，因为它们通常面向任务，所以其特定功能应当对应少量正常流量模式。尽管存在拟合常见流量模式（由频繁动作生成）的倾向，自编码器也成功捕获了不频繁动作（例如启动）的模式，这一点通过较低的 FPR 得到了证明。在真实世界应用中，可以通过调整 tr 和 ws 来调整 FPR，不过这会以 TPR 和检测时间为代价。

5 结论 (CONCLUSION)

尽管我们的实验中自编码器在测试集的大多数物联网设备上取得了零 FPR，但剩余物联网设备之间 FPR 的差异促使我们进一步分析数据。我们观察到，Philips B120N/10 婴儿监视器相对于其他设备表现出最高的 FPR；它还产生了大量的流量（见表 3），因此人们可能预计，大量训练实例会带来更稳健的机器学习模型。然而，该设备也拥有最为多样的功能，因为它配备了双向对讲功能、运动检测、音频检测，以及环境光、温度和湿度等若干其他传感器。鉴于此，捕捉其正常行为可能更加困难，因此未来观测可能出现更多分类错误。

据此，我们提出假设：捕捉正常流量行为的难度因物联网设备而异，并且这种难度可能与（1）设备的功能以及（2）设备通常产生的网络通信相关。文献 [2] 也提出了类似观点，认为当今物联网设备的专用功能会产生可预测的行为。反过来，物联网设备易于建立基线行为，便于使用异常检测作为检测攻击的手段。由此产生了以下有趣问题：

- ☐ 物联网设备流量行为的可预测性能够量化吗？
- ☐ 可否将可预测性水平与物联网设备的静态特征（例如传感器的数量和类型、内存大小、操作系统）或动态特征（例如每小时唯一目的 IP 的数量、出站与入站流量比值的方差）之间的关系形式化？
- ☐ 能否根据这些特征对其对可预测性水平的影响进行排序？

我们推测，流量行为的可预测性可以直接转化为异常检测的性能度量。例如，流量可预测性高的物联网设备会使任何异常动作都格外突出，因此在这种情况下 TPR 应当提高、检测时间应当缩短。为进行实证验证，我们从（良性）训练集中提取了静态和动态特征。然后，我们训练回归模型，研究这些特征对四种检测方法在测试集上取得的平均 FPR 和检测时间的影响。图 2(c) 和图 2(d) 通过最显著的特征描绘了我们的初步发现。图 2(c) 显示，入站流量的可变性增加会转化为更大的平均 FPR ($p\text{-value}=0.019$)。这很合理，因为较低的可预测性容易通过不可预测但良性的流量行为表现出来，从而被错误地识别为异常。图 2(d) 显示，入站流量最大值增加会导致 ($p\text{-value}=0.001$) 更长的检测时间。由于我们优化 ws 以在 DSopt 上达到 0% FPR，较低的可预测性会导致更大的 ws （更多用于多数投票的实例），随后导致更长的检测时间。

最终，大型组织可以利用稳健的可预测性评分来确保网络功能并限制遭入侵设备可能造成的影响。也就是说，安全策略可能不允许可预测性评分低的物联网设备连接到其网络，因为这类设备难以检测攻击。在未来工作中，我们计划进一步定义并研究流量可预测性这一主题，包括理论研究和实证研究。

作为当前研究的另一项扩展，我们还计划评估迁移学习技术：考察在特定设备上训练的模型应用于相同设备时的准确率，包括这些设备可能连接到其他组织网络的情形。这有助于：（1）节省时间（例如，组织可以部署此前在其他地方学习的模型，而无需自行收集数据和训练模型）；（2）检测在连接到组织网络之前就被污染的遭入侵物联网设备，因为组织没有这些设备的良性数据来训练模型。

致谢 (ACKNOWLEDGMENTS)

作者感谢 Yan Lin Aung、Amit Subhashchandra Tambe、Simon Dzanashvili 和 Tar Wolfson 所作的宝贵贡献。

参考文献 (REFERENCES)

- [1] C. Kolias、G. Kambourakis、A. Stavrou 和 J. Voas，“物联网中的 DDoS: Mirai 与其他僵尸网络 (DDoS in the IoT: Mirai and Other Botnets)” , *Computer*, 第 50 卷, 第 7 期, 第 80–84 页, 2017 年。
- [2] E. Bertino 和 N. Islam，“僵尸网络与物联网安全 (Botnets and Internet of Things Security)” , *Computer*, 2017 年。

- [3] R. Hallman, J. Bryan, G. Palavicini, J. Divita 和 J. Romero-Mariona, “IoDDoS: 分布式拒绝服务攻击互联网——Mirai 恶意软件和基于物联网的僵尸网络案例研究 (IoDDoS The Internet of Distributed Denial of Service Attacks – A Case Study of the Mirai Malware and IoT-Based Botnets)”, 载于 *Proceedings of the 2nd International Conference on Internet of Things, Big Data and Security – Volume 1: IoTBDS*, SciTePress, 2017 年, 第 47–58 页。
- [4] M. Ozcelik, N. Chalabianloo 和 G. Gur, “针对基于物联网的 DDoS 的软件定义边缘防御 (Software-Defined Edge Defense Against IoT-Based DDoS)”, 载于 *2017 IEEE International Conference on Computer and Information Technology (CIT)*, IEEE, 2017 年, 第 308–313 页。
- [5] D. H. Summerville, K. M. Zach 和 Y. Chen, “面向物联网设备的超轻量级深度数据包异常检测 (Ultra-lightweight deep packet anomaly detection for Internet of Things devices)”, 载于 *2015 IEEE 34th International Performance Computing and Communications Conference, IPCCC 2015*, 2016 年。
- [6] Y. M. P. Pa, S. Suzuki, K. Yoshioka, T. Matsumoto, T. Kasama 和 C. Rossow, “IoT POT: 揭示当前物联网威胁的新型蜜罐 (IoT POT: A Novel Honeypot for Revealing Current IoT Threats)”, *Journal of Information Processing*, 第 24 卷, 第 3 期, 第 522–533 页, 2016 年。
- [7] H. Sedjelmaci, S. M. Senouci 和 M. Al-Bahri, “面向低资源物联网设备的轻量级异常检测技术: 一种博弈论方法 (A lightweight anomaly detection technique for low-resource IoT devices: A game-theoretic methodology)”, 载于 *2016 IEEE International Conference on Communications (ICC)*, IEEE, 2016 年, 第 1–6 页。
- [8] H. Bostani 和 M. Sheikhan, “使用基于 MapReduce 方法的无监督 OPF 的物联网基于异常和基于规范的 IDS 混合 (Hybrid of anomaly-based and specification-based IDS for Internet of Things using unsupervised OPF based on MapReduce approach)”, *Computer Communications*, 2017 年。
- [9] I. Butun, B. Kantarci 和 M. Erol-Kantarci, “以云为中心的物联网中的异常检测与隐私保护 (Anomaly detection and privacy preservation in cloud-centric Internet of Things)”, 载于 *2015 IEEE International Conference on Communication Workshop (ICCW)*, IEEE, 2015 年, 第 2610–2615 页。
- [10] D. Midi, A. Rullo, A. Mudgerikar 和 E. Bertino, “Kalis: 面向物联网的知识驱动自适应入侵检测系统 (Kalis A System for Knowledge-Driven Adaptable Intrusion Detection for the Internet of Things)”, 载于 *2017 IEEE 37th International Conference on Distributed Computing Systems (ICDCS)*, IEEE, 2017 年, 第 656–666 页。
- [11] S. Raza, L. Wallgren 和 T. Voigt, “SVELTE: 物联网中的实时入侵检测 (SVELTE: Real-time intrusion detection in the Internet of Things)”, *Ad Hoc Networks*, 第 11 卷, 第 8 期, 2013 年。
- [12] B. B. Zarpelo, R. S. Miani, C. T. Kawakani 和 S. G. de Alvarenga, “物联网入侵检测综述 (A survey of intrusion detection in Internet of Things)”, *Journal of Network and Computer Applications*, 第 84 卷, 第 25–37 页, 2017 年 4 月。
- [13] A. Tuor, S. Kaplan, B. Hutchinson, N. Nichols 和 S. Robinson, “结构化网络安全数据流的无监督内部威胁深度学习 (Deep learning for unsupervised insider threat detection in structured cybersecurity data streams)”, 载于 *Artificial Intelligence for Cybersecurity Workshop at AAAI*, 2017 年。
- [14] S. Garcia, A. Zunino 和 M. Campo, “基于网络的僵尸网络检测方法综述 (Survey on network-based botnet detection methods)”, *Security and Communication Networks*, 第 7 卷, 第 5 期, 第 878–903 页, 2014 年。

[原文此处无法识别]: 参考文献 [14] 中作者名在原文文本提取中出现乱码 (`Garcia`), 未对其进行猜测或改写。

- [15] I. Arnaldo, A. Cuesta-Infante, A. Arun, M. Lam, C. Bassias 和 K. Veeramachaneni, “学习网络安全中的日志数据表示 (Learning Representations for Log Data in Cybersecurity)”, 载于 *International Conference on Cyber Security Cryptography and Machine Learning*, Springer, 2017 年, 第 250–268 页。

- [16] Y. Li、R. Ma 和 R. Jiao, “基于深度学习的混合恶意代码检测方法 (A hybrid malicious code detection method based on deep learning)”, *International Journal of Security and Its Applications*, 第 9 卷, 第 5 期, 2015 年。
- [17] K. Veeramachaneni、I. Arnaldo、V. Korrapati、C. Bassias 和 K. Li, “Ai²: 训练一台大数据机器进行防御 (Ai²: training a big data machine to defend)”, 载于 *Big Data Security on Cloud, IEEE International Conference on High Performance and Smart Computing (HPSC), and IEEE International Conference on Intelligent Data and Security (IDS), 2016 IEEE 2nd International Conference on*, IEEE, 2016 年, 第 49–54 页。
- [18] Y. Yu、J. Long 和 Z. Gai, “通过堆叠扩张卷积自编码器进行网络入侵检测 (Network intrusion detection through stacking dilated convolutional autoencoders)”, *Security and Communication Networks*, 第 2017 卷, 2017 年。
- [19] “GitHub – jgamblin/Mirai-Source-Code: 用于研究/loC 开发目的的泄露 Mirai 源代码 (Leaked Mirai Source Code for Research/loC Development Purposes)”。[在线]。可用:
`https://github.com/jgamblin/Mirai-Source-Code`
- [20] N. Blenn、V. Ghie[□]tte 和 C. Doerr, “通过互联网反向散射量化拒绝服务攻击的频谱 (Quantifying the Spectrum of Denial-of-Service Attacks through Internet Backscatter)”, 载于 *Proceedings of the 12th International Conference on Availability, Reliability and Security – ARES '17*, ACM Press, 2017 年, 第 1–10 页。

[原文此处无法识别]: 参考文献 [20] 中作者名在原文文本提取中出现乱码 (`Ghie<sup>□</sup>tte`), 未对其进行猜测或改写。

作者简介 (原文末页)

****Yair Meidan**** 是内盖夫本-古里安大学 (Ben-Gurion University of the Negev, BGU) 软件与信息系统工程系 (Department of Software and Information Systems Engineering, SISE) 的博士候选人。他的研究兴趣包括机器学习和物联网安全。联系方式: `yairme@post.bgu.ac.il`。

****Michael Bohadana**** 是 BGU SISE 系的理学硕士 (M. Sc.) 学生。他的研究兴趣包括逆向工程和物联网安全。联系方式: `bohadana@post.bgu.ac.il`。

****Yael Mathov**** 是 BGU SISE 系的理学硕士 (M. Sc.) 学生。她的研究兴趣包括物联网安全和逆向工程。联系方式: `yaelmath@post.bgu.ac.il`。

****Yisroel Mirsky**** 是 BGU SISE 系的博士候选人。他的研究兴趣包括机器学习和时间序列异常检测。联系方式: `yisroel@post.bgu.ac.il`。

****Dominik Breitenbacher**** 是新加坡科技设计大学 (Singapore University of Technology and Design, SUTD) iTrust 网络安全中心的研究助理。他的研究兴趣包括物联网安全和恶意软件检测。联系方式: `dominik@sutd.edu.sg`。

****Asaf Shabtai**** 是 BGU SISE 系的助理教授。他的研究兴趣包括计算机与网络安全以及机器学习。联系方式: `shabtaia@bgu.ac.il`。

****Yuval Elovici**** 是 BGU Telekom Innovation Laboratories 主任、BGU 网络安全研究中心负责人、SUTD 的 iTrust 研究主任以及 BGU SISE 系教授。他的研究兴趣包括计算机与网络安全以及机器学习。联系方式: `yuval.elovici@sutd.edu.sg`。

附录 (APPENDIX)

原文未包含附录。